

MEANS OF COMPLIANCE AND RELATION BETWEEN SECURITY STANDARDS IN AIRWORTHINESS ENGINEERING

Anna Baron Garcia, Radu F. Babiceanu, and Remzi Seker

*Department of Electrical, Computer, Software, and Systems Engineering,
Embry-Riddle Aeronautical University, Daytona Beach, FL 32114*

Abstract

In the current networked society, there is a critical need to secure all safety-critical physical and cyber systems and their communications. This security assurance process must be done in coordination with the safety assurance process, such that the required safety levels are not affected. Aviation and aerospace domains security standards are the guidelines industry, and research enterprises must follow to ensure security in the skies.

This proposed study builds an in-depth framework of the relation of the current airworthiness security standards, as well as suggested guidelines to integrate the framework with airworthiness safety standards for concurrent security and safety engineering. The concurrent security and safety assurance processes are used as inputs to the aircraft design and development process, and as a means for aircraft implementation verification, and validation and certification processes.

Introduction

Currently, the skies are full of aircraft that have gone through extensive tests and are heavily regulated to ensure the safety of the passengers and crew. Decades ago, before the Information Technology Era, aircraft had to be regulated for safety engineering. Nowadays, with the power of the internet at everyone's fingertips, the aviation industry has had to adapt and start regulating information security as well.

In 2010, RTCA developed the Airworthiness Security Process Specification (RTCA DO-326, 2010), a first document intended to increase current guidance for aircraft certification to handle the information security threats to aircraft safety. The document established compliance objectives and data requirements paralleled with the expected activities for aircraft development and certification. The document was later updated (Airworthiness Security

Process Specification, RTCA DO-326A, 2014), and offers guidance for aircraft certification to handle threats of intentional unauthorized electronic interaction to aircraft safety. At the same time, RTCA developed another document, the Information Security Guidance for Continuing Airworthiness (RTCA DO-355, 2014), which addresses concerns regarding continuing airworthiness and development. The document became a resourceful guideline for the operation and maintenance of an aircraft, and the actions that need to be taken during those stages related to information security threats. It also acknowledges the effects of information security threats that could affect aircraft safety. Another document, Airworthiness Security Methods and Considerations (RTCA DO-356, 2014) provides guidance in the areas of Security Risk Assessment and Analysis, and Effectiveness Assurance, which were previously identified in RTCA DO-326, and presents methodologies for Security Risk Analysis and Network Security Domains.

All these guideline documents and standards are intended to be used with other development assurance activities, outlined in frameworks and standards such as SAE ARP 4754A, SAE ARP 4761, DO-178C, and DO-254, in substantiation of compliance to the applicable Code of Federal Regulations.

The primary goal of the RTCA DO-326A, DO-355 and DO-356A standards was to provide a much-needed framework for Airworthiness Security that was also intended to be part of the Systems Engineering and system life-cycle. This allowed for a sense of holistic security in Security Airworthiness and provided some guidance to confront future threats from the always-evolving new technologies.

This paper is organized as follows: Section II presents a general understanding of the current regulatory legislative framework for aviation law and regulations, the differences between hard law and soft law, and the process of standardization and

certification for airworthiness security. Section III explains the current RTCA standards for airworthiness security and presents a relation model for all other standards and regulations, highlighting the relation between security and safety in those standards. Section IV details the means of compliance with the previous standards. Finally, this paper is concluded in Section V, and a list of acronyms is provided in Section VII.

Background

There is one apparent problem with regulation and legislation when it comes to air law. A plane can leave the United States, with cargo from Brazil, heading to the European Union, and it has to comply with all regulation and laws (both international and local). This presents a paradigm of regulation and standardization that was not considered when the aircraft was first designed for commercial flight.

A conference for the formulation of international air law was held in Paris in 1900. However, international air travel only became a reality after World War I (1914 – 1918). The legal framework for international civil aviation first appears in October 1919. Twenty-six participants of the Paris Peace Conference signed the Convention for the Regulation of Aerial Navigation (Paris Convention). [1, 2] The Paris Convention coined the principle that every state has the absolute and exclusive sovereignty over the airspace above its territory.

Later, fifty-four nations met in Chicago from November to December 1944 to “make arrangements for the establishment of world air routes and associated services” and “to set up an interim council to collect, record, and study data concerning international aviation with the aim to make recommendations for its improvement”. The Conference was also invited to “discuss the principles and methods to be followed in the adoption of a new aviation convention” [3]. It also led to the creation of the agency of the International Civil Aviation Organization (ICAO). In 1947, ICAO became a United Nations specialized agency, even though it remained an independent and autonomous agency.

Three of the most relevant articles of the Chicago Convention, article 31 (Certificates of Airworthiness), article 32 (Licenses of personnel) and article 33 (Recognition of Certificates and Licenses)

provide a collection of rules that allow for aircraft certification of airworthiness to be issued, provided by single states and also allow for those same certifications to be recognized by other states, as long as the requirements under which they have been issued are equal or above the minimum standards which may be established by ICAO. Therefore, a framework of regulatory oversight between states, operators, services providers and maintenance organizations was created. The relationships are shown in Table 1.

Table 1. Regulatory Framework

Regulatory Framework		Legislative	Actor	Action
International and Aviation Law		Conventions	Government	Oversight
National Law	Regional Rules and Law		Government Authorities	Oversight
National Regulation	Regional Regulation		Authorities	Establish Rules and Requirements
Standards and Industry Best Practices			Service Providers Manufacturers	Compliance

The aforementioned regulatory legislative framework needs to make a clear distinction: the difference between a regulation and a standard.

To answer this [2, 4], the concept of ‘hard law’ and ‘soft law’ of aviation need to be addressed. In aviation law, administrative law and decisions can have different names and come from different fields, and those are broken down into technical specifications, acceptable means of compliance and guidance material. Hard law is those regulations by authorities and government, which are legally binding in nature. Soft law refers to the non-legally binding nature of technical specifications and guidance material. Even though they are not legally binding, they provide standardization and implementation of rules and requirements stipulated by regulations. In a way, ‘soft law’ is a detailed version of the simple and brief rules that make ‘hard law’.

Table 2 shows the entities that are in charge of managing the different documents (e.g. regulations, specifications, standards) of aviation law.

Table 2. Hard Law and Soft Law Entities

Law	Document	Entity
Hard Law	International Convention/Law	ICAO
Hard Law	Regulation, Implementation Rules	FAA EASA
Soft Law/ Hard Law	Technical Specification Standards	ARINC EUROCAE RTCA
Soft Law	Acceptable Means of Compliance	FAA EASA
Soft Law	Guidance Material	EUROCAE RTCA

Once there is a clear understanding of where the regulatory framework is coming from and what it entails, there is a need to know which regulations and what framework is used for aviation safety: Airworthiness and its certification (Figure 1).

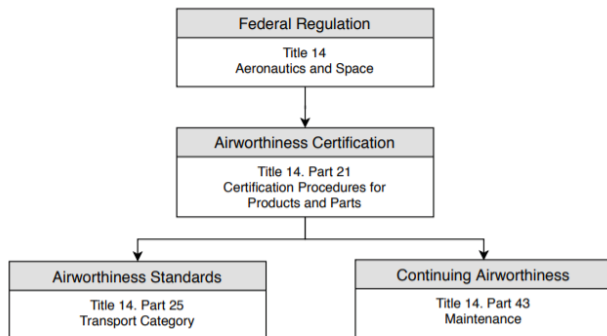


Figure 1. Framework for Aviation Safety (United States)

Then there are the Industry Standards, in particular, for the purpose of this paper, the industry standards that refer to security. As a general concept, industry standards are defined and accepted as the minimum requirements in order to comply with an industry code of practices or regulations. Standards are a means of regulatory compliance. In other

words, operators and service providers that are being trusted to comply with regulation and legislation will not procure systems do not adhere or that are not produced according to a minimum set of practices and demonstrate required performance.

Security Standards for Airworthiness

Security standards for Airworthiness are a rather new concept. The previous security standards for aviation that had been presented two decades ago did not conceive aviation security engineering as a holistic part of the system's life-cycle, but rather technical reports on specific parts of the system. Nowadays, standardization and regulations for aviation security strive to achieve a well-rounded framework to cover the complete spectrum of the system's life-cycle, and it can be mapped onto a system engineering perspective. This includes the certification of the assessment of the system for compliance with the appropriate aviation rules. Airworthiness certificates are issued for aircraft that are built (designed and assembled) according to accepted standards by a holder of a production certificate for manufacturing and based on evidence (standard practices/methods, testing) of compliance with a type certificate [2].

Airworthiness

Airworthiness is the measure of an aircraft's suitability for safe flight, as defined in [5]. From the aircraft operators perspective, the principal certification instrument is Airworthiness. Aircraft manufacturers have to prove through a stage-based approach that the design and development of the aircraft have resulted in an aircraft that can be safely operated. Airline operators have to ensure continued airworthiness through the establishment of processes for operations and maintenance.

Ensuring Airworthiness Security (as part of Airworthiness Engineering) while integrating it into the systems engineering framework led to the publication of DO-326, DO-356, and DO-355. Those standards have a rather complex relation with other existing standards and regulations for aviation security. In this paper, a relation framework overview is presented (Figure 2).

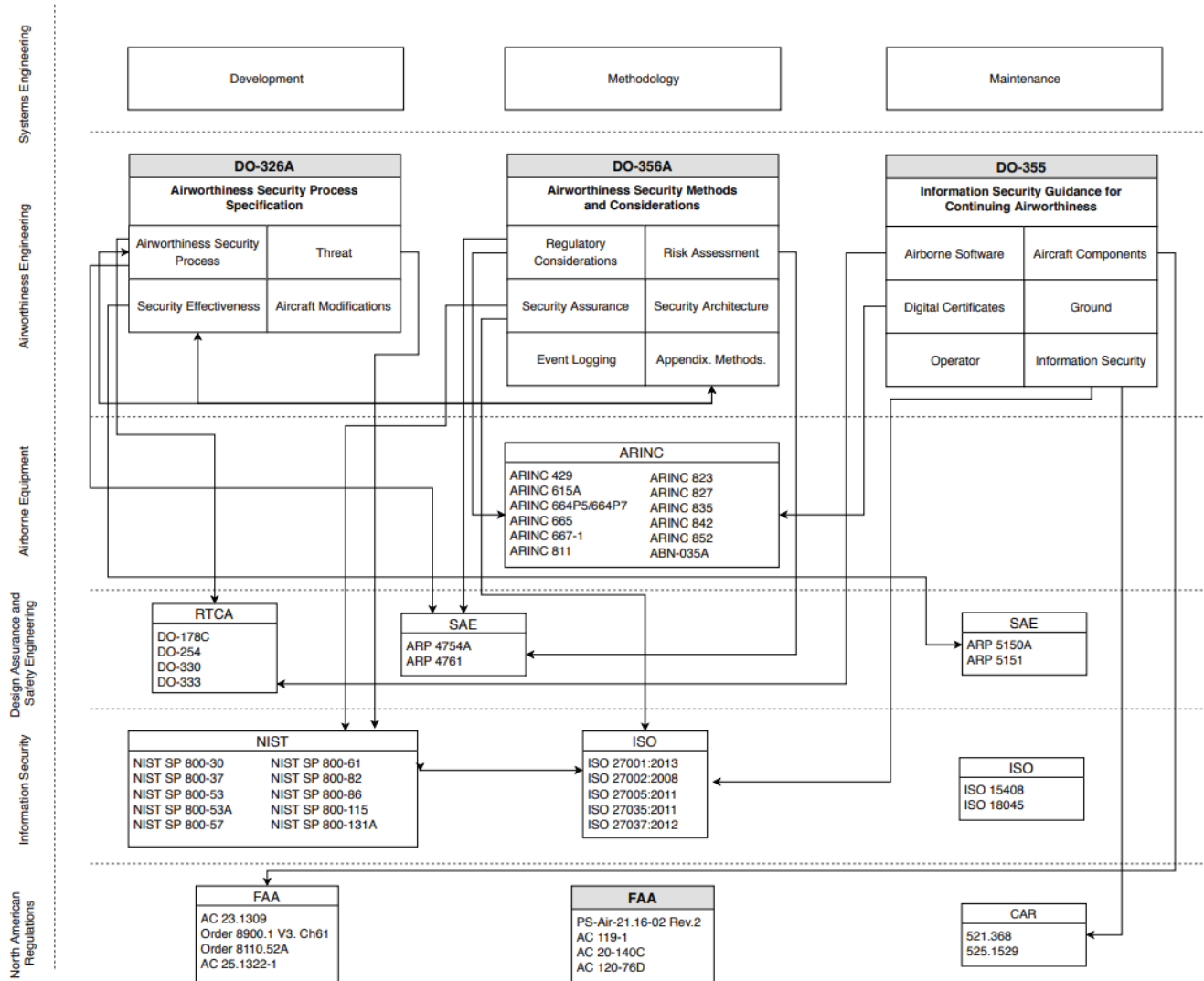


Figure 2. Relations between Security Standards in Airworthiness Engineering

Airworthiness Engineering

Security Airworthiness currently follows three standards in the North American framework (as opposed to four standards and one reference document in the European Union).

DO-326A

DO-326A, 2014 Airworthiness Security Process Specification is a resource for Airworthiness Authorities (AA) and the aviation industry for certification when the development or modification of an aircraft systems and the effects of intentional unauthorized electronic interaction can affect aircraft safety.

It deals with the activities that need to be performed in support of the airworthiness process when it comes to the threat of intentional unauthorized electronic interaction. [5, 6]

DO-356A

DO-356A, 2018 was developed in context of the Airworthiness Security Process Specification (DO-326A) which addresses type certification considerations during the first three life cycle stages of an aircraft type (Initiation, Development and Acquisition, and Implementation) and in the context of the information Security Guidance for Continuing

Airworthiness (RTCA DO-355) which addresses airworthiness security for continued airworthiness.

The methods and considerations of this document address the assessment of the acceptability to system safety and airworthiness and provide guidance for accomplishing the activities identified in RTCA DO-326A and specific methods for Security Risk Analysis and Network Security Domains. [7]

DO-355

DO-355, 2014. The Information Security Guidance for Continuing Airworthiness is a resource for civil aviation authorities and the aviation industry when the operation and maintenance of aircraft and the effects of information security threats can affect aircraft safety.

The listed documents deal with the activities that need to be performed in the operation and maintenance of the aircraft related to information security threats. These documents also offer guidance that is related to operations and commercial effects (such as guidance that exceeds the safety-only effects). [8]

These three standards for Security Airworthiness have many dependencies on other standards at different points of the system life-cycle, as can be seen in Figure 2.

Airborne Equipment

ARINC Industry Activities efforts for aviation security are focused within the focused within the Airlines Electronic Engineering Committee (AEEC) responsible for approximately 300 ARINC Standards. They correspond to standards that focus on data communication, the evolution of new systems using the Internet Protocol Suite (IPS) and data bus, among other aspects of security. Nowadays, they are extensively used on commercial aircraft [9].

The ARINC standards that are referenced within the Security Airworthiness are:

- *ARINC 429*: Data Bus. Ensures data integrity by checking parity.
- *ARINC 615A*: Software Data Loader Using Ethernet Interface.
- *ARINC 664P5/664P7*: Data Network. Presents network domain characteristics

and interconnection, and the avionics Full-Duplex switched Ethernet networks.

- *ARINC 665*: Electronic Distribution of Software.
- *ARINC 667-1*: Guidance for the Management of Field Loadable Software.
- *ARINC 811*: Commercial Aircraft Information Security Concepts of Operation and Process Framework. It facilitates an understanding of aircraft information security and guides the development of aircraft information security operational concepts.
- *ARINC 823*: DataLink Security. It provides recommended guidance and provisions for ACARS Message Security (AMS) key management.
- *ARINC 827*: Electronic Distribution of Software.
- *ARINC 835*: Guidance for Security of Loadable Software Parts Using Digital Signatures. It presents a general background and detailed technical information on existing methods to secure loadable software parts.
- *ARINC 842*: Guidance for Usage of Digital Certificates. It provides guidance for key life-cycle management, which refers to the phases through which digital certificates and associated cryptographic keys progress, from creation through usage to retirement.
- *ARINC 852*: Guidance for Security Event Logging in an IP Environment. It provides guidance for IP-based onboard networks and systems residing in the Airline Information Services (AIS) and Passenger Information and Entertainment Services (PIES) domains.
- *ABN-035A ARINC Technical Application Bulletin*: provide information to system engineers preparing industry standards for networked systems to ensure that appropriate cyber security provisions are included in emerging systems.

All ARINC Standards also incorporate security concepts from other standards and are referenced through the Security Airworthiness of RTCA DO-

326A, DO-356A, DO-355 in regards to technical aspects.

Design Assurance and Safety Engineering

The RTCA and SAE have several standards that cross-reference each other when it comes to safety engineering and design assurance.

RTCA

- *DO 178C*: Software Considerations in Airborne Systems and Equipment Certification. It provides recommendations for the productions of software for airborne systems and equipment that performs its intended function with a level of confidence in safety that complies with airworthiness requirements. They are process-based software development assurance standards that define five software criticality levels, Development Assurance Levels (DALs), from E to A upwards [6].
- *DO 254*: Design Assurance Guidance for Airborne Electronic Hardware. It provides guidance to be used by aircraft manufacturers and suppliers of electronic hardware items used in aircraft systems.
- *DO 330*: Software Tool Qualification Considerations. It provides software tool qualification guidance for airborne and ground-based software and explains the process and objective for qualifying tools, which can also be used by other domains, such as safety assessment process.
- *DO 333*: Formal Methods Supplement to DO-178C and DO-278A. It is used to identify the additions, modifications, and deletions to RTCA DO-178C, 2011 and RTCA DO-278A objectives when used as a part of a software life cycle.

SAE

- *ARP 4754A*: Guidelines for Development of Civil Aircraft and Systems. Its main goal is ensuring that the aircraft functions are correct and complete. They do provide additional certification considerations for very integrated complex aircraft systems; and address the complete life-cycle for

systems that implement aircraft level functions.

- *ARP 4761*: Guidelines and Methods for Conducting the Safety Assessment Process on Civil Airborne Systems Equipment. It provides guidelines to perform the safety assessment for certification of civil aircraft, consisting of a Functional Hazard Assessment (FHA), a Preliminary System Safety Assessment (PSSA), and a System Safety Assessment (SSA). It also presents information on the safety analysis methods needed to conduct the safety assessment.
- *ARP 5150A*: Safety Assessment of Transport Airplanes in Commercial Service. It presents guidelines, methods, and tools used to perform the ongoing safety assessment process for transport airplanes in commercial service.
- *ARP 5151*: Safety Assessment of General Aviation Aircraft and Rotorcraft in commercial use. It describes a process that may be used to perform the ongoing safety assessment for the aircraft and its components.

Information Security

Apart from the aviation industry-specific standards, there are several standards that present Information Security frameworks that can be implemented in different industries. The standards referenced in the RTCA DO-326A, DO-355, DO-356A are:

NIST SP 800-x Series

The NIST Special Publications are a set of documents that describe United States federal government computer security policies. Those policies can also be applied at different stages of Security Airworthiness development.

- *NIST SP 800-30*: Guide for Conducting Risk Assessments.
- *NIST SP 800-37*: Guide for Applying the Risk Management Framework to Federal Information Systems: A Security Life Cycle Approach.
- *NIST SP 800-53 / 800-53A*: Security and Privacy Controls for Federal Information

Systems and Organizations, and Guide for Assessing the Security Controls in Federal Information Systems and Organizations, Building Effective Security Assessment Plans

- *NIST SP 800-57*: Recommendation for Key Management: Part 1: General.
- *NIST SP 800-61*: To quantify how much damage will be caused if a threat is exploited.
- *NIST SP 800-82*: Guide to Industrial Control Systems Security.
- *NIST SP 800-86*: Guide to Integrating Forensic Techniques into Incident Response.
- *NIST SP 800-115*: Technical Guide for Information Security Testing and Assessment.
- *NIST SP 800-131A*: Transitions: Recommendation for Transitioning the Use of Cryptographic Algorithms and Key Lengths.

ISO 27000 Series

The ISO/IEC 27000 series are general information security standards that help organizations keep information assets secure. They are mostly methodology management focused.

- *ISO 27001:2013*: Information technology - Security techniques: Information security management systems and Requirements.
- *ISO 27002:2008*: Information technology - Security techniques: Code of practice for information security management
- *ISO 27005:2011*: Information Security Risk Management.
- *ISO 27035:2011*: Information Security Incident Management.
- *ISO 27037:2012*: Guidelines for identification, collection, acquisition and preservation of digital evidence.

ISO / Common Criteria

The ISO/IEC organization published the Common Criteria for Information Technology Security as the following standards:

- *ISO 15408*: To quantify how much damage will be caused if a threat is exploited.
- *ISO 18045*: To quantify how much damage will be caused if a threat is exploited.

North American Regulations

As aforementioned in the previous section, several regulation agencies impose regulations for aviation security. This paper only covers those that affect the North American region, given that the European Union has its own set of regulations (which most of the time they overlap with the North American ones).

FAA Regulations

The Federal Aviation Administration (FAA) has some regulations for Airworthiness, as mentioned in Section II. These regulations play a substantial part in Airworthiness Security.

- *AC 23.1309*: Equipment, Systems Installations in Part 23.
- *Order 8900.1 Volume 3. Chapter 61*: Aircraft Network Security Program (ANSP).
- *Order 8110.52A*: Type Validation and Post-type Validation Procedures.
- *AC 25.1322-1*: Flight Crew Alerting.

CAR Regulations

As part of the North American framework for regulations CAR (Canadian Aviation Regulations) are also referenced:

- *521.368*: Instructions for Continuing Airworthiness.
- *525.1529*: Instructions for Continuing Airworthiness.

Means of Compliance and Alternative Means of Compliance

Acceptable means of compliance (AMC) target the uniform application and implementation of the regulation. The principal purpose of AMCs is to further qualify material used for certification and demonstrate compliance with these requirements. Although regulated entities are not bound by AMCs and may choose to demonstrate compliance through

other means, AMCs provide a means to the presumption of compliance.

In our case, Means of Compliance for Security Airworthiness would result in regulations referring to the Security Airworthiness standards RTCA DO-326A, DO-355, DO-356A and providing evidence of complying with those standards.

Policies and Regulations (FAA)

There are currently four main policies and regulations from the FAA that use or reference the Airworthiness Security Standards DO-326A, DO-355, DO-356A:

- FAA AC 119-1: (2015) Airworthiness and Operational Authorization of Aircraft Network Security Program (ANSP).
- FAA AC 20-140C: (2016) Guidelines for Design Approval of Aircraft Data Link Communication Systems Supporting Air Traffic Services (ATS).
- FAA PS-Air-21.16-02 Rev. 2: (2017) Establishment of Special Conditions for Aircraft Systems.
- FAA AC 120-76D: (2017) Authorization for Use of Electronic Flight Bags, New Security Procedures.

In a way, Means of Compliance is a way to facilitate the certification task for both the regulator and the entity. The adherence to those ensures recognition of compliance with rules.

If an applicant chooses to comply by other means, it must show that it provides for compliance with the applicable specification or requirement. In these cases, the burden of proof of compliance wholly rests with the applicant. This is why most authorities and applicants try to adhere to the Means of Compliance of a set of standards or regulations because proving compliance in any other way can result in an arduous task.

Conclusions

Even though the aviation industry is known for not making rapid changes when it comes to regulation and standardization, it has seen the

emerging new technologies as a potential threat and has acted accordingly.

A new wave of Security Airworthiness standards (DO-326A, DO-355, DO-356A) has been published in the last five years, addressing the security assessment gap that appeared due to the progressive interconnection of the aircraft in the new sky.

Also, these standards are somewhat complex, and they rely on other standards (both from the aviation industry and general information standards). To prove the argument for the fast standardization of Airworthiness, the FAA has already included the Security Airworthiness Standards in its policies and regulations.

Finally, the relation between security standards for Airworthiness can seem overwhelming when implementing any of the standards suggested guidelines; therefore, a framework of relation has been presented in this paper.

References

- [1] The Postal History of ICAO. The 1919 Paris Convention: The Starting Point for the Regulation of Air Navigation. [Online] Available: https://www.icao.int/secretariat/postalhistory/1919_the_paris_convention.htm
- [2] G. Markarian, R. Kolle and A. Tarter. Aviation Security Engineering: A Holistic Approach. Artech House Publishers, 2011.
- [3] Icao.int. (2019). Introduction. [Online] Available at: <https://www.icao.int/ChicagoConference/Pages/chicago-conference-introduction.aspx>
- [4] "Overview" EASA. [Online] Available at: www.easa.europa.eu/document-library/agency-rules-overview
- [5] DO-326A, Airworthiness Security Process Specification, RTCA 2014.
- [6] ITEA2, Recommendation for Security and Safety Co-engineering, Merge Safety & Security Std., March 2016.
- [7] DO-356A Airworthiness Security Methods and Considerations, RTCA, 2018.
- [8] DO-355 The Information Security Guidance for Continuing Airworthiness, RTCA, 2014.
- [9] ARINC. Aviation Cyber Security Efforts. Airlines Electronic Engineering Committee (AEEC). 2018

Acronyms

A list of all acronyms used in this paper is provide for reference purposes in Table 3.

Table 3. Acronyms

Acronym	Description
AA	Airworthiness Authorities
AC	Advisory Circulars
AEEC	Airlines Electronic Engineering Committee
AIS	Airline Information Services
AMC	Acceptable Means of Compliance
AMS	ACARS Message Security
ARINC	Aeronautical Radio, Incorporated
ARP	Aerospace Recommended Practice
CAR	Canadian Aviation Regulations
DALs	Development Assurance Levels
DO	Document
EASA	European Aviation Safety Agency
EU	European Union
EUROCAE	European Organization for Civil Aviation Equipment
FAA	Federal Aviation Administration
FAR	Federal Aviation Regulations

FHA	Functional Hazard Assessment
ICAO	International Civil Aviation Organization
IPS	Internet Protocol Suite
ISO	International Organization for Standardization
NIST	National Institute of Standards and Technology
PIES	Passenger Information and Entertainment Services
PSSA	Preliminary System Safety Assessment
RTCA	Radio Technical Commission for Aeronautic
SAE	Society of Automotive Engineers
SSA	System Safety Assessment

Email Addresses

Anna Baron Garcia: barongaa@my.erau.edu

Radu F. Babiceanu: babicear@erau.edu

Remzi Seker: sekerr@erau.edu

*2019 Integrated Communications Navigation
and Surveillance (ICNS) Conference
April 9-11, 2019*